

CSCI 530: COMPUTER SECURITY SYSTEMS

RESEARCH PAPER

Name: Aaron Lobo
ID: 9160382742

I have read the Guide to Avoiding Plagiarism published by the student affairs office. I understand what is expected of me with respect to properly citing sources, and how to avoid representing the work of others as my own. The material in this paper was written by me, except for such material that is quoted or indented and properly cited to indicated the sources of the material. I understand that using the words of others, and simply tagging the sentence, paragraph, or section with a tag to the copied source does not constitute proper citation and that if such materiel is used verbatim or paraphrased it must be specifically conveyed (such as through the use of quotation marks or indentation) together with the citation. I further understand that overuse of properly cited quotations to avoid conveying the information in my own words, while it will not subject me to diciplinary action, does convey to the instructor that I do not understand the material enough to explain it in my own words, and will likely result in a lesser grade on the paper.

Signed: Aaron Savio Lobo

Plenty of Phish in the Sea:

Overview and Analysis of Phishing Attacks

Abstract— This paper highlights the overall phishing process, the different types of channels used for this attack, the techniques used, real-life phishing attacks, the types of phishing attacks, and the countermeasures. The channel used (vector) is how the phishing email is delivered to the target by the attacker. The techniques used section talks about how various psychological and technical methods are used in crafting the attack. The attacks can be classified into different types based on a collection of factors that include channel and technique used, motive of attacker, etc. The real-life phishing attack examples show that these attacks can be used as the starting vector for many major attacks leading to financial losses, data leaks, and political conflicts. This paper also explains the countermeasures that can help keep organizations and individuals safe from such attacks by using appropriate tools and adequate training.

Keywords—*phishing, countermeasures, tools, insert, techniques.*

I. INTRODUCTION

Phishing attacks target the weakest link in security, the human rather than software vulnerabilities. Phishing can be described as a type of semantic attack where attackers target victims in order to extract confidential information like account numbers, passwords, or other personal information [1]. These attacks are simple to use but can cause damaging results to individuals or organizations. Hackers used the term “phishing” for the first time when they stole American Online (AOL) accounts in 1996 by tricking users into revealing their passwords [2]. Phishing attacks use email as a primary attack vector, a mode of communication that is very common in most organizations.

They tend to trick users into thinking they are major companies. LinkedIn was the most imitated company globally in Q1 of 2022. It accounted for 52% of the total phishing emails that imitated organizations [3]. They were followed by DHL which accounted for 14%, Google which accounted for 7%, Microsoft for 6%, and FedEx for 6%. The attackers impersonate employees at senior positions in organizations

and target freshers who are looking for jobs to get their personal information. Attackers are getting better at crafting these emails making it difficult for a user to determine whether the email is legitimate or not.

The victims are pressured or tricked into clicking a link, replying, or entering some information in response to these emails by an attacker impersonating another individual or organization. This leads to major financial losses and losses of confidential information. This paper talks about the different types of phishing attacks and countermeasures to such attacks.

II. VECTORS FOR PHISHING

Emails are the primary attack vectors for phishing. However, there are many channels an attacker can use to phish a victim.

A. Email

Many organizations use emails to communicate since it helps you keep track of previous conversations too. Using emails, messages can be sent to a large number of recipients easily. In order to understand how phishing is done through emails, it is important to understand the workings of emails. An email consists of a header and a body. The header contains the following fields [10]:

- From – Senders Email
- To – Recipients Email
- Date – Date when the email was sent.

The above three fields are compulsory while the header also contains optional fields like:

- Received – Information about the intermediary server.
- Reply-To – An email address to which the reply will be sent.
- Subject – The subject of the email
- Message ID – Unique ID for the message

Email addresses have the following structure: joe@xyz.com where “joe” is the mailbox and “xyz.com” is the domain.

Email communications at a high-level work in the following way[11]:

- The sender will create an email on the mail client. Using the SMTP protocol, it will go to the SMTP server of the sender's domain.
- The SMTP server queries the DNS server to locate the receiver's domain.
- The DNS server finds the IP address corresponding to the recipient's domain and sends it back to the sender's SMTP server.
- This SMTP server will now send the email across the internet. It may pass through multiple intermediary SMTP servers before it reaches the destination which is the destination domain outbound SMTP server.
- The email is then sent to a server running POP3 or IMAP which lets the recipient use an email client to view the email.

There are many ways in which an attacker can use emails for phishing. The sender can change the sending email address to appear like it's coming from a legitimate company. There may be malicious links that lead to fake websites that are controlled by the attackers in the body of the email or malware embedded in files in the attachments that come along with emails. An attacker may use social engineering techniques to make the victims click the link or download that file. A collection of multiple such techniques is used by attackers to craft a phishing email.

B. Smishing

If the vector used to phish is SMS/MMS, it's called smishing [13]. This name is derived from text messaging technology (SMS). Smishing targets Personal Identification Information (PII) and takes advantage of the fact that the security team of an organization does not have visibility of SMS. As said in [4], the attacker pretends to be a trusted authority like a bank and has a link in the message that leads to a fake website where the victim is asked to log in. This information goes straight to the attacker. The link could also lead to a website that hosts malware that gets downloaded into the user's phone from where the attacker can continue with the attack using the malware.

C. Vishing

Vishing uses IP-based voice messaging technologies (Voice over IP Protocol) as an attack vector for phishing. The attacker uses social engineering tactics to get confidential information from the victim [13]. The reasons why this form of phishing is effective are Trust (It's more likely for a person to trust a phone call), Call Centres (People are used to getting calls from call centers asking for details), and Age of the Victim [14] (Compared to emails, a large number of the older population is available through telephones).

D. Social Media

With the internet becoming for accessible as time progresses, the number of users on social media websites is also increasing. They enable users to connect with others who have similar interests [4]. A lot of these users lack the security awareness to not click untrusted links. An attacker may create a fake account and create a post that contains a link that

downloads malware. With the large number of people on social media, some are bound to click it leading to their devices getting corrupted. (Instagram scams)

These social media websites have quizzes that promise to tell the user "Which celebrity they are like" or "Where would they be in 20 years". An attacker can create a quiz that asks very specific questions to give the user some random result. The user answers these questions unaware that it was created by an attacker who uses the information in these answers to create phishing emails that appear more legitimate. The attacker could also sell the information that it gathered to a third party [12].

E. Wireless Phishing

In wireless phishing, phishing is done by taking advantage of Wi-Fi functionality on devices. People tend to connect to open Wi-Fi networks in public places like hotels or airports or sometimes, their devices are configured to automatically connect to open networks. The attacker could "phish" the victim into connecting to their own hotspot by manipulating the configuration of their hotspot like in the Evil Twin attack discussed in part X. When the victim is connected to their hotspot, they can view the traffic and gather any personal information that is sent through it [12].

III. TECHNIQUES AND TACTICS

A. Social Engineering

Social Engineering uses persuasion techniques to manipulate people into performing actions or divulging confidential information [14]. This is a major part of phishing attacks, and the success of the attack depends on this. The attacker uses social engineering to manipulate the user into taking their bait from the phishing attack. The five principles of persuasion that are used in social engineering are [14]:

- Authority – People usually do not question authority and hence, will follow what they are instructed to do.
- Social Proof – If everyone is doing something, they will not be the only ones who make the mistake.
- Liking, Similarity, and Deception – People are more likely to share details with someone they like.
- Distraction – Distractions affect people's emotional state, affecting their ability of logical reasoning.
- Commitment, Reciprocation, and Consistency – People are likely to do something if they publicly state it. They want to be consistent with their words and actions.

Attackers use these principles or a combination of principles while creating their bait. Liking, Similarity, and Deception are the most effective of these based on the analysis from [14]. The victim will let their guard down if they find anything in common or they like someone, so the attacker may do research beforehand and find out the victim's favorite sport and subtly mention it in the phishing message.

B. Typosquatting

When a user makes a mistake in typing the domain name in the browser for the website they want to visit, instead of receiving an error for entering the wrong domain, they land on

a website that is registered under that wrong domain name [12]. Sometimes, it is difficult to differentiate what is wrong with the domain name. Attackers take advantage of this inability of humans to differentiate at first glance if there are any characters changed. They use domain names that closely resemble the legitimate domain names. For example, “Faceboook.com” resembles “Facebook.com”. An attacker registers Faceboook.com to their malicious website which might be an identical copy of the Facebook login page. They send this URL in any of the phishing channels discussed above. The victim at first glance will not be able to differentiate the fake link and hence, trust it to be coming from Facebook and click it. They end up logging into the fake page and now the attacker has their credentials. They can also use emails from this domain in order to impersonate legitimate Facebook and trick users into thinking it was sent by a Facebook employee.

C. Combo Squatting

Combo Squatting is similar to typosquatting in the sense that it uses a modification of legitimate domain names to be more effective. In this, the attacker will add a word or phrase to extend the original domain name. For example, “Facebook-support.com”, The word “support” is added. Since it does not affect the original “Facebook” spelling, and organizations usually try to expand their service scope by registering combined domains, it becomes more believable [14]. The attacker will impersonate a person from Facebook support and send this squatted link to the user using a phishing channel. This user thinks this will take them to Facebook’s support where they enter their credentials and get successfully compromised by the attacker.

D. Homographs

Different characters can have the same appearance even if they are coded differently in Unicode. These are called homographs [14]. The attacker takes advantage of this to make the attached URL to the phishing email or the domain from which the email is coming, more believable. For example, Greek “ο” and Latin “o” though the same in appearance, are considered different characters. An attacker can register a domain using this undatable different character and make their malicious website or email address look like it came from a legitimate one.

E. HTML Styling

Many attackers add HTML styling to their phishing emails to make them look more legitimate. They try to imitate popular websites. We can see in Image 1 that the attacker tried to impersonate Amazon by using HTML in the email. Using social engineering, the attacker pressures the victim into clicking the hyperlink which most probably will lead to a credential harvester.

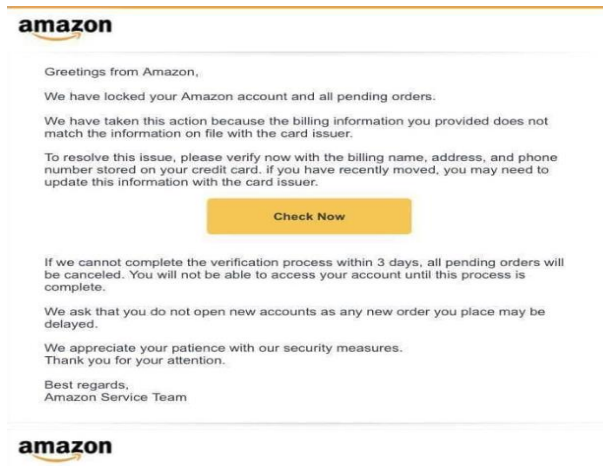


Image 1 [24]

F. Sender-ID Spoofing

The “FROM” header in emails can be spoofed. The attacker can change it to make it seem that the email is coming from another person or a well-known company.

G. Attachments

Using email attachments, the attacker can put malware onto the victim’s computer. The content of the email will entice or force the user into downloading the malicious attachment depending on the social engineering tactics we discussed above. However, the attachment could also be non-malicious and purely for social engineering purposes to make it more believable. For example, an attacker could impersonate a new hire and attach a fake signed form. The attached could also be non-malicious but have a malicious hyperlink or URL inside the document. The attachment could also be an Excel file with malicious macros that get executed when the user downloads it.

H. URL Shortening

URL shortening services like Bitly enable attackers to hide the malicious URL that they send in a phishing email [12]. This makes it harder for the victim to determine where the URL leads to. This shortened link redirects the victim to the actual long link when clicked. An example of a Bitly shortened URL can be “bit.ly/2vyqzQ”. As we can see, just by looking at this URL you cannot determine where it leads to.

IV. TYPES OF PHISHING EMAILS:

This section talks about the different types of phishing emails based on the techniques they use, the attackers’ motives, and the medium used for the attack.

A. Reconnaissance

i. Spam reconnaissance email

The attacker sends an email that is empty or a random message. If an undelivered email error arises, it means that the email address does not exist. If no error is seen, that means

that the email address exists and could be a potential victim of a phishing attack.

ii. Social engineering reconnaissance email

This is known as an impersonation attack in which the malicious attacker will use social engineering tactics to bait the potential victim into giving a response. The attacker poses as someone who the victim knows or someone higher up in the company and creates a sense of fear and urgency [4]. An example of the content of such an email could be, "I have an important meeting coming up, hope you sent the presentation". The victim would respond to this out of fear and hence, the attacker knows that this inbox is active and could be further attacked.

iii. Tracking pixel reconnaissance email

Pixel trackers can be paired with the above two types of reconnaissance emails. In this email, a one-by-one undetectable pixel is inserted in the email. When the victim opens up this email, it lets the attacker know that the email has been opened. This is typically used in marketing to gather information about a user. Through this technique, an attacker can get a list of all the email addresses that opened this email and thus, consider them as active for a future phishing attack [5].

B. Spear Phishing

In contrast to normal phishing attacks where targets are chosen blindly and in huge numbers, spear phishing is a targeted approach. In this, an individual is targeted by a well-crafted email that an attacker creates using intelligence gathered on the victim. This intelligence may contain information that the victim would not expect the attacker to know. Hence, this type of phishing email has a higher chance of being successful in comparison to mass phishing emails due to its exploitation of human psychological factors [6]. According to [4] the success of the spear phishing attack relies on the following aspects of human psychology – Authority, Commitment, Liking, Contrast, Reciprocity, Scarcity, and social proof. For example, an attacker sends a phishing email acting like the CEO of the company to a manager telling him that he needs the Excel sheet of the recent transactions made by the company. The manager feels pressured due to the authority imposed by the attacker who impersonates the CEO.

C. Whaling

Similar to Spear Phishing, Whaling is a highly targeted attack. However, Whaling focuses on phishing higher-level employees in an organization that has a lot of authority like the C-level executives. The attackers try to make this email look as legitimate as possible and spend time gathering specific information about the target. A successful whaling attack is catastrophic as these targets are individuals who have privileged accounts thus giving them access to more information[7].

D. QRishing

Barcodes are being replaced by QR codes since QR codes are less readable by the human eye and can store much more data compared to barcodes. In the case of numbers, barcodes

can hold only up to 20 digits while QR codes can store 7089 numbers [8]. QR stands for quick response and is a layout of black-and-white pixels that are used to communicate information [4]. This QR code is usually decoded using an optical scan which is present in the cameras of mobile phones. Due to the increase in the use of mobile phones and the advantages of QR codes, they are being widely used.

Since users typically use their mobile phones to scan QR codes, there is often less protection. Some scanners directly open the data in the QR code when scanned. Due to this, to user cannot see the URL the code redirects to. This QR code could lead to a malicious fake website that asks users to enter their credentials or could directly lead to malware being downloaded on the victim's device [9].

A QRishing attack would typically be through email where a deceptive message is sent along with the malicious QR code. The victim scans this QR code using their mobile phone leading them to a malicious website with a fake login screen. Once the user enters their details, they go straight to the attacker.

E. Wiphishing

In this type of phishing attack, the attacker uses the wireless channel for phishing. The "bait" here is the attacker configuring his own wireless access point that has the same SSID and frequency of a legitimate one in order to create an evil twin. The attacker usually uses this kind of bait in places with public places like hotels or airports where people tend to use public Wi-Fi. Once the user connects to this malicious access point, the attacker can access all the information that the victim sends in the network traffic[4].

RECENT PHISHING CAMPAIGNS

This section highlights real-world phishing attacks that have taken place in recent years. We can see the different types of attacks, different channels, and different techniques used by attackers. From the examples below, we can see that the attackers range from 17-year individuals to Advanced Persistent Threats (APTs) funded by the government. The motives of the attacks range from financial gain to political motives. Even a simple attack such as phishing can be a starting point for a massive compromise.

- Twitter Attack 2020

Looking at the analysis from [15], the attack vector used here was phone calls, hence it is an example of spear vishing. The hacker took advantage of the whole COVID-19 work-from-home phase. Since employees were working remotely, they had to use VPN services to access Twitter's servers. The attacker set up a fake website that looked like the VPN provider's website. The employees then received calls from the attacker and his accomplices instructing them to go to this fake website and submit their credentials to reset their passwords along with the MFA codes. The vishing attacks were targeted, the attacker kept using information he gained from previous employees to finally phish and get hold of an employee's account that had access to the account support tools. From there, the attacker compromised high-profile accounts

including Binance, Elon Musk, Uber, Apple, etc. He created posts from these accounts which tricked users into sending Bitcoin to his Bitcoin wallet by stating that the money will be doubled. This is essentially social media as a channel for phishing. The attacker was able to gain \$117,000 in Bitcoin and download information about the accounts compromised.



Image 2 [25]

- Facebook and Google Attack 2013 – 2015

This attack used email as the channel for phishing. The attacker impersonated one of the Facebook and Google vendors, a Taiwan-based company called Quanta Computer. The attacker and his accomplices created fake invoices, contracts, and letters. They then sent these invoices to the employees of Google and Facebook who oversaw handling transactions with the real Quanta. The sent documents along with the email were convincing enough for these employees to wire \$100 million between the years 2013 and 2015 [16].

- Discord Attack

Discord has become a very popular platform for different communities to form groups and communicate with each other. In August 2023, Bloomberg shared a tweet that redirected users to their Telegram group. However, in October 2023, they updated their Telegram name. The attacker was able to get hold of the old Telegram name and hence, users who were clicking the link on the post made in August 2023 were getting redirected to a Telegram group that was controlled by the attacker. In this group, the attacker had a link posted to join a fake Bloomberg discord server. Some Discord servers require users to verify themselves through an authentication bot called “AltDentifier”. This fake server too, had a bot that prompted the new members to get verified but instead of using the legitimate link (altdentifier[.]com), used a link that lead to a malicious website (altdentifiers[.]com). As we can see, the malicious website used the technique “typosquatting” by adding an additional “s” at the end of the domain name which is easily missed by the human eye. This website made users verify themselves using their discord credentials, leading to a compromise of their accounts [17]. The attackers then used these accounts to seem legit and created more phishing messages that focused on stealing cryptocurrency from other users. This is an example of using social media as a channel for phishing along

with using social engineering and typosquatting techniques.

- Ukrainian Power Grid Attack 2015

The report from [18] states that on a cold December night in 2015, Ukraine’s power grid was taken down by hackers, leaving people in the dark. The credit for this attack was given to a Russian APT (Advanced Persistent Threat) called Sandworm, however, there is no evidence of it. This massive attack used spear phishing as an initial attack vector. This email used a malicious attachment, a document which when clicked on executes macros leading to their devices being infected by the “BlackEnergy3” malware which opened a backdoor for the attackers. These phishing emails were targeted towards System Administrators of the company. Using these backdoors, they further escalated the attack by getting credentials for VPN access to the SCADA network. With access to the SCADA network, they first took down the backup power supply. They took down a few substations and overwrote firmware with malicious firmware and finally used the “KillDisk” malware to wipe the files from operator stations and prevent them from rebooting.

V. COUNTER MEASURES

As we have seen throughout this paper, a phishing attack could be the initiation vector that leads to major and more complicated attacks. For any organization or individual, it is essential to protect their system by having security measures in place to avoid taking the “bait” and eventually getting “phished”. The following methods can be used:

A. Extracting and Analysing Artifacts

Section II. A. explained the structure of an email. Based on that, we can collect important information (artifacts) from these emails that can be analyzed to prevent future attacks. The main goal of this is to gather and share intelligence about artifacts that may indicate a potential phishing attack taking place. These artifacts are generally used by security tools to create filters and improve antivirus software. If any of the artifacts get flagged in the malicious stage, blocks can be applied at the email gateway.

Information from the email:

- FROM address – The sender’s email address. This can be used to block emails coming from the same attacker. However, if they use multiple email IDs, this will not be effective. The block can be bidirectional.
- Subject – Subject of the email. Most phishing campaigns use the same subject in all of their emails since their focus is quantity over quality. Hence, blocking emails having the same subject can be useful.
- Recipients – All the email IDs that the email was sent to. Knowing all the employees to whom the phishing

email was sent can help in identifying to whom a warning email should be sent.

- **Sending Server IP** – Downloading the email and opening it with a text editor will let you find the IP of the mail server from which the mail was sent. The attacker may use multiple mail servers having different IPs reducing the effectiveness of this block.
- **Reverse DNS** – Using the sender IP, reverse DNS lookups can be performed using online tools that give us the hostname and information on the server.
- **Date & Time** – The date and time of receiving the email can be found in the email client. Knowing the date and time of the email helps identify phishing attacks belonging to the same campaign.
- **Reply-To Address** – The reply-to address can be found by opening the email in a text editor. This is the actual address that the reply to the email will go to. In case the sender spoofed they're from address, knowing the reply-to address can help in identifying the real sender.

Information from the attached file:

- **File name** – The name of the attached file. Blocking emails based on file names should only be used if the attachment name is unique enough. Blocking a malicious attachment name that is unique not could result in legitimate attachments getting blocked. For example, blocking the filename "vendor_invoice" is a bad idea.

Blocking certain attachment types that are known to be malicious and do not affect the functioning of the business is important like .exe (Executables), .vbs (Visual Basic Script), .js (JavaScript), iso (Optical Disk Image, etc)

- **File hash value** – The hash of the file can be obtained by downloading the file in a safe environment like a virtual machine and then using the get-hash command in Windows or the sha256sum/sha1sum/md5sum command on Linux. Malicious attachment hashes can be blocked using Endpoint Detection and Response tools (EDR). However, polymorphic malware edits itself and hence its hash value keeps changing due to which, it can bypass this kind of block.
- **File size** – Checking the properties of the file can give information about the size.

Information from the mentioned URL

- **Complete URL** – However over the link and click copy URL. A safer way to do this is to search for "<a>/http" when you open the email in a text editor to avoid clicking on the link by mistake. A URL can be blocked using the web proxy, however, changing the URL even the slightest can make this block

ineffective. Hence blocking URLs at specific points can be more effective Eg: "http://dogpictures[.]com/index/xyz/12/outlook/owa.php?" Blocking from the first suspicious directory (xyz) "http://dogpictures[.]com/index/xyz/" would block any URLs that have the specific directory in them.

Analyzing these artifacts:

After gathering these artifacts from the suspicious email, they need to be analyzed. This can be done using online tools.

- **URL visualization and reputation**

Using the "Complete URL" artifact that you gathered from the email above, you can visualize how the URL looks. This lets you counter shortened URLs that hide where the URL redirects to and also lets you further analyze the website for indicators of it being a malicious website without having to go to the website and risk an unsecured connection. URLScan and URL2PNG are online tools that give you a screenshot of the webpage. You can also check how long a domain name has been used since using the tool Wannabrowser. If it's a relatively newer one, there are more chances of it being a malicious webpage since it indicates that an attacker created it purely for phishing purposes.

This artifact can be put through a URL reputation check which finds matches in a URL database that has previously known malicious URLs. A reputation score assigned to a URL is a good indicator of it being malicious [22]. However, this method is only useful against previously known malicious URLs, a new URL might go undetected and show a good reputation score.

- **File Reputation**

File hashes are a good way to verify the integrity of a file. It can be used as an identifier for a file. Using the file hash value of the attached file in the suspicious email, you can check for its reputation. It's similar to a URL reputation check, it checks from a database of previously known malicious file hashes so a new file could be given a good reputation score. VirusTotal and Talon File Reputation (by Cisco) are online tools that can be used for this purpose.

- **Malware Sandboxing**

Malware sandboxing is downloading the malicious file attachment and letting it execute in a dedicated environment typically virtual environments in order to keep it isolated from the production systems. Sandboxing allows monitoring of the behavior of the malware [23]. The information gathered from this can be used to create defenses for similar activities.

B. Email Security

Since Email is the most popular mode used for phishing and also a common channel for employees of organizations to communicate, it is essential to have

security measures in place that prevent and detect phishing emails.

- Marking external emails by altering the subject line or body is a good way to make users more aware while dealing with them. A word like “[EXTERNAL]” is usually added.
- Email filters can reduce the number of messages reaching the inbox of the employees and the number of alerts being generated to the security team of the organization.
- Most major email providers use ML-based filtering techniques due to the large number of spam emails. These filters adapt to types of emails and create new rules on their own.
- DNS Records

DNS records are rules of a particular server that are implemented into an authoritative domain server. They are used to authenticate the sender to ensure that unauthorized individuals do not use the domain to send emails and hence prevent sender ID spoofing.

- Sender Policy Framework (SPF)

This domain record prevents someone from spoofing an email address from your domain. The record contains the hostnames or IP addresses that are allowed to send emails as the domain. If the IP address of the sending email is not in the record, the message fails SPF authentication [23]. The SPF text consists of 3 parts: the declaration of the record type, IP addresses/external domains allowed to be sent on your domain's behalf, and an enforcement rule.

- Domain Keys Identified Mail (DKIM)

This DNS record is used to ensure the integrity of the email being sent and verify the sender of the email using digital signatures [23]. The domain using this record will store its public key as a DNS record. The contents of any email sent by this domain is hashed using a private key and the hash is added to the email header as a DKIM signature. The receiving server will check the domain's DNS records for the public key and decrypt the email. It will then generate a new hash and match it with the original hash to ensure integrity.

- Domain-based Message Authentication Reporting and Conformance (DMARC)

DMARC depends on SPF and DKIM [23]. The DMARC record is also published on

the DNS server. First, the DMARC and SPF authentication is checked by the recipient on the domain's DNS server when a sender sends an email from their domain. After these checks are performed, if they fail the DMARC policy is checked. It is used to specify whether the email should be quarantined, or rejected or nothing should be done. A report can be sent to an email ID mentioned in the DMARC record about this email.

C. Security Awareness Training

The main target of phishing attacks is the human. No matter how secure the system is, if the person operating does not have the security awareness necessary, the system will get compromised if targeted by an attacker. Users should educate themselves to recognize phishing attacks along with organizations giving compulsory training to teach users how to recognize and react to phishing emails.

Often even if users in an organization are given training, they do not pay attention. Training and education in the form of games and interactive training have proved to be more effective based on research [19]. Training on phishing has positively improved the users' knowledge, behavioral tendencies, and ability to identify phishing attacks [20].

Phishing Simulations conducted on an organization give an overview of the employees' awareness. In this, employees are sent phishing emails either by a third-party company or the security team of the organization. These emails are intentionally designed to appear as phishing emails and are sent to all employees. The link embedded in this email leads to a webpage created by the team carrying out the simulation and is a safe webpage notifying the employees that they fell for the phishing attack. The details of these employees are noted down and a second round of phishing emails are sent. The people who still fall victim to this simulated attack should be given separate additional training. Data from a phishing simulation campaign at an Italian Hospital revealed that out of the 2600 people that were included, in the first round of the simulation, 55% of the people fell for the attack, while in the second round, 21% fell for it, and in the final round just 3% of the employees' fell for it [21]. Hence, the users' awareness of phishing increased as the rounds of simulation progressed.

By paying attention to the fine details in emails, an individual could identify possible indications of a phishing attack. A lot of these emails contain spelling mistakes and have errors in the HTML formatting they use in the body. Users should be aware and be very cautious about clicking links or downloading files.

VI. CONCLUSION

This paper provided an overview of phishing attacks and how wide their application is. Phishing remains the most common attack as time progresses. It exploits the psychological reasoning and technical skills of the human behind the system. The attacker uses social engineering and other technical techniques to craft phishing emails. Even the most secure systems can be compromised if any of its users

fall prey to a successful phishing attack. The real-world examples of phishing showed us that the attackers can be highly sophisticated groups or just a single person. These attacks could lead to the compromise of critical system infrastructures or simply stolen cryptocurrency from individuals. Not just organizations but individuals should also take measures to educate themselves on identifying possible phishing attacks. Extracting information (artifacts) from emails and analyzing them helps detect phishing attacks. These artifacts can be used to create filters and share intelligence among organizations to prevent falling prey to similar phishing campaigns. These attackers are getting “craftier” by the day and are making phishing emails hard to detect even with advanced filters in place. Filters can only reduce the number of phishing emails reaching the users beyond that, it is all in the hands of the user. Until users are more aware and practice proper cyber hygiene, phishing attacks will continue to be the most popular mode for attackers to get into secure systems.

REFERENCES

- [1] Yue Zhang, Serge Egelman, Lorrie Cranor, and Jason Hong Carnegie Mellon University zysxqn@andrew.cmu.edu, {egelman, lorrie, jasonh}@cs.cmu.edu
- [2] Fighting against phishing attacks: state of the art and future challenges B. B. Gupta1 • Aakanksha Tewari1 • Ankit Kumar Jain1 • Dharma P. Agrawal2
- [3] D. Imber, “The Latest Phishing Statistics (updated October 2023) | AAG IT Support,” *AAG IT Services*, Oct. 06, 2023. <https://aag-it.com/the-latest-phishing-statistics/>
- [4] R. Alabdhan, “Phishing Attacks Survey: Types, Vectors, and Technical Approaches,” *Future Internet*, vol. 12, no. 10, p. 168, Sep. 2020, doi: 10.3390/fi12100168.
- [5] C. Cimpanu, “Email tracking pixels used for Pre-Hack info gathering,” *BleepingComputer*, Apr. 18, 2017. [Online]. Available: <https://www.bleepingcomputer.com/news/security/email-tracking-pixels-used-for-pre-hack-info-gathering/>
- [6] D. D. Caputo, S. L. Pfleeger, J. D. Freeman and M. E. Johnson, “Going Spear Phishing: Exploring Embedded Training and Awareness,” in *IEEE Security & Privacy*, vol. 12, no. 1, pp. 28-38, Jan.-Feb. 2014, doi: 10.1109/MSP.2013.106.
- [7] Shankar, A.; Shetty, R.; Nath, B. A Review on Phishing Attacks. *Int. J. Appl. Eng. Res.* 2019, 14, 2171–2175
- [8] N. A. Sankara, “QR Codes and Security Solutions,” *International Journal of Computer Science and Telecommunications [Volume 3, Issue 7, July 2012]*, vol. 3, no. 7, pp. 69–72, [Online]. Available: https://www.ripublication.com/ijaer19/ijaerv14n9_15.pdf
- [9] “QR code Scams & Phishing - Cybersecurity Stop of the Month | ProofPoint US,” *Proofpoint*, Oct. 19, 2023. <https://www.proofpoint.com/us/blog/email-and-cloud-threats/cybersecurity-stop-month-qr-code-phishing>
- [10] O. Al-Jarrah, I. Khater, and B. Al-Duwairi, “Identifying Potentially Useful Email Header Features for Email Spam Filtering,” *ICDS 2012 : The Sixth International Conference on Digital Society*, Art. no. ISBN: 978-1-61208-176-2, 2012
- [11] G. Chhabra and D. Bajwa, “Review of E-mail System, Security Protocols and Email Forensics,” *International Journal of Computer Science & Communication Networks*, vol. 5(3), Art. no. ISSN:2249-5789, [Online]. Available: https://www.researchgate.net/profile/Gurpal-Chhabra/publication/286053691_Review_of_Email_System_Security_Protocols_and_Email_Forensics/links/5665afcd08ae418a786f1f7d/Review-of-E-mail-System-Security-Protocols-and-Email-Forensics.pdf
- [12] G. Sonowal, *Phishing and Communication Channels: A Guide to Identifying and Mitigating Phishing Attacks*, 1st Edition, 1st Edition. Place of publication not identified: Apress, 2021.
- [13] Yeboah-Boateng, E.O.; Amanor, P.M. Phishing, SMiShing & Vishing: An Assessment of Threats against Mobile Devices. *J. Emerg. Trends Comput. Inf. Sci.* 2014, 5, 297–307.
- [14] Y. Zeng, T. Zang, Y. Zhang, X. Chen and Y. Wang, “A Comprehensive Measurement Study of Domain-Squatting Abuse,” ICC 2019 - 2019 IEEE International Conference on Communications (ICC), Shanghai, China, 2019, pp. 1-6, doi: 10.1109/ICC.2019.8761388.
- [15] Social-Engineer, “Analyzing the 2020 Twitter attack - Security Boulevard,” *Security Boulevard*, Jan. 20, 2021. <https://securityboulevard.com/2021/01/analyzing-the-2020-twitter-attack/>
- [16] T. Huddleston Jr, “How this scammer used phishing emails to steal over \$100 million from Google and Facebook,” *CNBC*, Mar. 27, 2019. [Online]. Available: <https://www.cnbc.com/2019/03/27/phishing-email-scam-stole-100-million-from-facebook-and-google.html>
- [17] S. Gatlan, “Bloomberg Crypto X account snafu leads to Discord phishing attack,” *BleepingComputer*, Nov. 17, 2023. [Online]. Available: <https://www.bleepingcomputer.com/news/security/bloomberg-g-crypto-x-account-snafu-leads-to-discord-phishing-attack/>

[18] K. Zetter, "Inside the cunning, unprecedented hack of Ukraine's power grid," *WIRED*, Mar. 03, 2016. [Online]. Available: <https://www.wired.com/2016/03/inside-cunning-unprecedented-hack-ukraines-power-grid/>

[19] Annetta LA. Video games in education: why they should be used and how they are being used. *Theory Pract.* 2008;47(3):229–39. doi:10.1080/00405840802153940

[20] Sahar Farshadkhah, Michele Maasberg, T. Selwyn Ellis & Craig Van Slyke. (2023) [An Empirical Examination of Employee Information Security Advice Sharing](#). *Journal of Computer Information Systems* 0:0, pages 1-16.

[21] Rizzoni F, Magalini S, Casaroli A, Mari P, Dixon M, Coventry L. Phishing simulation exercise in a large hospital: A case study. *DIGITAL HEALTH.* 2022;8. doi:10.1177/20552076221081716

[22] Chia-Mei Chen, Jhe-Jhun Huang, Ya-Hui Ou, Efficient suspicious URL filtering based on reputation, *Journal of Information Security and Applications*, Volume 20, 2015, Pages 26-36, ISSN 2214-2126, <https://doi.org/10.1016/j.jisa.2014.10.005>. (<https://www.sciencedirect.com/science/article/pii/S2214212614001410>)

[23] Estelle Derouet, Fighting phishing and securing data with email authentication, *Computer Fraud & Security*, Volume 2016, Issue 10, 2016, Pages 5-8, ISSN 1361-3723, [https://doi.org/10.1016/S1361-3723\(16\)30079-3](https://doi.org/10.1016/S1361-3723(16)30079-3). (<https://www.sciencedirect.com/science/article/pii/S1361372316300793>)

[24] J. MacKay, "How To Identify Amazon Email Scams (Before You Lose Money)," Jul. 10, 2023. <https://www.aura.com/learn/amazon-email-scams>

[25] "Hackers take over high profile Twitter accounts in Bitcoin scam," *SignDesk*, Jul. 17, 2020. <https://signdesk.com/in/cyber-security/hackers-take-over-high-profile-twitter-accounts-in-bitcoin-scam>